



only_web_no_api_admin_auth

Site: <https://localhost:8443>

Generated on Fri, 1 May 2026 16:24:30

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	3
Medium	5
Low	4
Informational	8

Insights

Level	Reason	Site	Description	Statistic
High	Exceeded High		Percentage of memory used	95
Low	Warning		ZAP errors logged - see the zap. log file for details	38
Low	Warning		ZAP warnings logged - see the zap. log file for details	93
Low	Exceeded High	https://localhost:8443	Percentage of slow responses	57 %
Info	Informational	http://localhost:8443	Percentage of responses with status code 4xx	100 %
Info	Informational	http://localhost:8443	Percentage of slow responses	39 %
Info	Informational	https://ajax.googleapis.com	Percentage of responses with status code 2xx	100 %

Info	Informational	https://ajax.googleapis.com	Percentage of endpoints with content type text/javascript	100 %
Info	Informational	https://ajax.googleapis.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://ajax.googleapis.com	Count of total endpoints	2
Info	Informational	https://ajax.googleapis.com	Percentage of slow responses	100 %
Info	Informational	https://archive.mozilla.org	Percentage of responses with status code 2xx	100 %
Info	Informational	https://archive.mozilla.org	Percentage of endpoints with content type application/x-xpinstall	100 %
Info	Informational	https://archive.mozilla.org	Percentage of endpoints with method GET	100 %
Info	Informational	https://archive.mozilla.org	Count of total endpoints	1
Info	Informational	https://archive.mozilla.org	Percentage of slow responses	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type application/javascript	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content	50 %

			type text /css	
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://cdn.jsdelivr.net	Count of total endpoints	4
Info	Informational	https://cdn.jsdelivr.net	Percentage of slow responses	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with content type application /octet-stream	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Count of total endpoints	1
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of slow responses	100 %
Info	Informational	https://fonts.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://fonts.googleapis.com	Percentage of endpoints with content type text /css	100 %
Info	Informational	https://fonts.googleapis.com	Percentage of endpoints with method GET	100 %

Info	Informational	https://fonts.googleapis.com	Count of total endpoints	1
Info	Informational	https://fonts.googleapis.com	Percentage of slow responses	100 %
Info	Informational	https://fonts.gstatic.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://fonts.gstatic.com	Percentage of endpoints with content type font /woff2	100 %
Info	Informational	https://fonts.gstatic.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://fonts.gstatic.com	Count of total endpoints	2
Info	Informational	https://fonts.gstatic.com	Percentage of slow responses	88 %
Info	Informational	https://localhost:8443	Percentage of responses with status code 2xx	45 %
Info	Informational	https://localhost:8443	Percentage of responses with status code 3xx	9 %
Info	Exceeded Low	https://localhost:8443	Percentage of responses with status code 4xx	23 %
Info	Exceeded Low	https://localhost:8443	Percentage of responses with status code 5xx	21 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type application /json	38 %
			Percentage of endpoints	

Info	Informational	https://localhost:8443	with content type image/jpeg	4 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type image/png	3 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type text/css	2 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type text/html	29 %
Info	Informational	https://localhost:8443	Percentage of endpoints with content type text/javascript	5 %
Info	Informational	https://localhost:8443	Percentage of endpoints with method GET	73 %
Info	Informational	https://localhost:8443	Percentage of endpoints with method POST	26 %
Info	Informational	https://localhost:8443	Count of total endpoints	194
Info	Informational	https://maps.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://maps.googleapis.com	Percentage of slow responses	86 %
Info	Informational	https://maps.gstatic.com	Percentage of responses with status code 2xx	100 %

Info	Informational	https://maps.gstatic.com	Percentage of slow responses	100 %
Info	Informational	https://places.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://places.googleapis.com	Percentage of slow responses	100 %
Info	Informational	https://source.unsplash.com	Percentage of responses with status code 5xx	100 %
Info	Informational	https://source.unsplash.com	Percentage of slow responses	100 %
Info	Informational	https://use.fontawesome.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://use.fontawesome.com	Percentage of endpoints with content type font /woff2	50 %
Info	Informational	https://use.fontawesome.com	Percentage of endpoints with content type text /css	50 %
Info	Informational	https://use.fontawesome.com	Percentage of endpoints with method GET	100 %
Info	Informational	https://use.fontawesome.com	Count of total endpoints	4
Info	Informational	https://use.fontawesome.com	Percentage of slow responses	97 %
Info	Informational	https://www.google.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://www.google.com	Percentage of slow responses	100 %

Alerts

Name	Risk Level	Number of Instances
Path Traversal	High	14
SQL Injection	High	1
SQL Injection - SQLite (Time Based)	High	1
Buffer Overflow	Medium	15
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Format String Error	Medium	6
Sub Resource Integrity Attribute Missing	Medium	Systemic
Vulnerable JS Library	Medium	1
Application Error Disclosure	Low	67
Cookie without SameSite Attribute	Low	Systemic
Cross-Domain JavaScript Source File Inclusion	Low	Systemic
Information Disclosure - Debug Error Messages	Low	63
Authentication Request Identified	Informational	3
GET for POST	Informational	17
Information Disclosure - Sensitive Information in URL	Informational	Systemic
Information Disclosure - Suspicious Comments	Informational	105
Modern Web Application	Informational	Systemic
Session Management Response Identified	Informational	18
User Agent Fuzzer	Informational	Systemic
User Controllable HTML Element Attribute (Potential XSS)	Informational	3

Alert Detail

High	Path Traversal
Description	The Path Traversal attack technique allows an attacker access to files, directories, and commands that potentially reside outside the web document root directory. An attacker may manipulate a URL in such a way that the web site will execute or reveal the contents of arbitrary files anywhere on the web server. Any device that exposes an HTTP-based interface is potentially vulnerable to Path Traversal. Most web sites restrict user access to a specific portion of the file-system, typically called the "web document root" or "CGI root" directory. These directories contain the files intended for user access and the executable necessary to drive web application functionality. To access files or execute commands anywhere on the file-system, Path Traversal attacks will utilize the ability of special-characters sequences. The most basic Path Traversal attack uses the "../" special-character sequence to alter the resource location requested in the URL. Although most popular web servers will prevent this technique from escaping the web document root, alternate encodings of the "../" sequence may help bypass the security filters. These method variations include valid and invalid Unicode-encoding ("..%u2216" or "..%c0%af") of the forward slash character, backslash characters ("..\") on Windows-based servers, URL encoded characters "%2e%2e%2f", and double URL encoding ("..%255c") of the backslash character. Even if the web server properly restricts Path Traversal attempts in the URL path, a web application itself may still be vulnerable due to improper handling of user-supplied input. This is a common problem of web applications that use template mechanisms or load static

	text from files. In variations of the attack, the original URL parameter value is substituted with the file name of one of the web application's dynamic scripts. Consequently, the results can reveal source code because the file is interpreted as text instead of an executable script. These techniques often employ additional special characters such as the dot (".") to reveal the listing of the current working directory, or "%00" NULL characters in order to bypass rudimentary file extension checks.
URL	https://localhost:8443/admin/review-hide/1?hide=1
Node Name	https://localhost:8443/admin/review-hide/1 (hide)(__csrf)
Method	POST
Attack	1
Evidence	
Other Info	
URL	https://localhost:8443/admin/tour-edit/1
Node Name	https://localhost:8443/admin/tour-edit/1 ()(__csrf,description,duration,hotelIncluded,imageFile,name,numPeople,price)
Method	POST
Attack	1
Evidence	
Other Info	
URL	https://localhost:8443/admin/tour-edit/1
Node Name	https://localhost:8443/admin/tour-edit/1 ()(__csrf,description,duration,hotelIncluded,imageFile,name,numPeople,price)
Method	POST
Attack	1
Evidence	
Other Info	
URL	https://localhost:8443/admin/tour-edit/1
Node Name	https://localhost:8443/admin/tour-edit/1 ()(__csrf,description,duration,hotelIncluded,imageFile,name,numPeople,price)
Method	POST
Attack	1
Evidence	
Other Info	
URL	https://localhost:8443/admin/tour-edit/1
Node Name	https://localhost:8443/admin/tour-edit/1 ()(__csrf,description,duration,hotelIncluded,imageFile,name,numPeople,price)
Method	POST
Attack	1
Evidence	
Other Info	
URL	https://localhost:8443/admin/tour-edit/2

Node Name	https://localhost:8443/admin/tour-edit/2 ()(_csrf,description,duration,hotelIncluded,imageFile,name,numPeople,price)
Method	POST
Attack	2
Evidence	
Other Info	
URL	https://localhost:8443/admin/tour-edit/2
Node Name	https://localhost:8443/admin/tour-edit/2 ()(_csrf,description,duration,hotelIncluded,imageFile,name,numPeople,price)
Method	POST
Attack	2
Evidence	
Other Info	
URL	https://localhost:8443/admin/tour-edit/2
Node Name	https://localhost:8443/admin/tour-edit/2 ()(_csrf,description,duration,hotelIncluded,imageFile,name,numPeople,price)
Method	POST
Attack	2
Evidence	
Other Info	
URL	https://localhost:8443/admin/users/edit/1
Node Name	https://localhost:8443/admin/users/edit/1 ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,secondaryPhone)
Method	POST
Attack	1
Evidence	
Other Info	
URL	https://localhost:8443/admin/users/edit/1
Node Name	https://localhost:8443/admin/users/edit/1 ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,secondaryPhone)
Method	POST
Attack	1
Evidence	
Other Info	
URL	https://localhost:8443/admin/users/edit/2
Node Name	https://localhost:8443/admin/users/edit/2 ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,secondaryPhone)
Method	POST
Attack	2
Evidence	

Other Info	
URL	https://localhost:8443/admin/users/edit/3
Node Name	https://localhost:8443/admin/users/edit/3 ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,secondaryPhone)
Method	POST
Attack	3
Evidence	
Other Info	
URL	https://localhost:8443/admin/users/edit/4
Node Name	https://localhost:8443/admin/users/edit/4 ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,secondaryPhone)
Method	POST
Attack	4
Evidence	
Other Info	
URL	https://localhost:8443/admin/users/edit/5
Node Name	https://localhost:8443/admin/users/edit/5 ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,secondaryPhone)
Method	POST
Attack	5
Evidence	
Other Info	
Instances	14
	Assume all input is malicious. Use an "accept known good" input validation strategy, i.e., use an allow list of acceptable inputs that strictly conform to specifications. Reject any input that does not strictly conform to specifications, or transform it into something that does. Do not rely exclusively on looking for malicious or malformed inputs (i.e., do not rely on a deny list). However, deny lists can be useful for detecting potential attacks or determining which inputs are so malformed that they should be rejected outright. When performing input validation, consider all potentially relevant properties, including length, type of input, the full range of acceptable values, missing or extra inputs, syntax, consistency across related fields, and conformance to business rules. As an example of business rule logic, "boat" may be syntactically valid because it only contains alphanumeric characters, but it is not valid if you are expecting colors such as "red" or "blue." For filenames, use stringent allow lists that limit the character set to be used. If feasible, only allow a single "." character in the filename to avoid weaknesses, and exclude directory separators such as "/". Use an allow list of allowable file extensions. Warning: if you attempt to cleanse your data, then do so that the end result is not in the form that can be dangerous. A sanitizing mechanism can remove characters such as '.' and ';' which may be required for some exploits. An attacker can try to fool the sanitizing mechanism into "cleaning" data into a dangerous form. Suppose the attacker injects a '.' inside a filename (e.g. "sensi.tiveFile") and the sanitizing mechanism removes the character resulting in the valid filename, "sensitiveFile". If the input data are now assumed to be safe, then the file may be compromised.

Solution	Inputs should be decoded and canonicalized to the application's current internal representation before being validated. Make sure that your application does not decode the same input twice. Such errors could be used to bypass allow list schemes by introducing dangerous inputs after they have been checked. Use a built-in path canonicalization function (such as <code>realpath()</code> in C) that produces the canonical version of the pathname, which effectively removes "." sequences and symbolic links. Run your code using the lowest privileges that are required to accomplish the necessary tasks. If possible, create isolated accounts with limited privileges that are only used for a single task. That way, a successful attack will not immediately give the attacker access to the rest of the software or its environment. For example, database applications rarely need to run as the database administrator, especially in day-to-day operations. When the set of acceptable objects, such as filenames or URLs, is limited or known, create a mapping from a set of fixed input values (such as numeric IDs) to the actual filenames or URLs, and reject all other inputs. Run your code in a "jail" or similar sandbox environment that enforces strict boundaries between the process and the operating system. This may effectively restrict which files can be accessed in a particular directory or which commands can be executed by your software. OS-level examples include the Unix chroot jail, AppArmor, and SELinux. In general, managed code may provide some protection. For example, <code>java.io.FilePermission</code> in the Java SecurityManager allows you to specify restrictions on file operations. This may not be a feasible solution, and it only limits the impact to the operating system; the rest of your application may still be subject to compromise.
Reference	https://owasp.org/www-community/attacks/Path_Traversal https://cwe.mitre.org/data/definitions/22.html
CWE Id	22
WASC Id	33
Plugin Id	6

High	SQL Injection
Description	SQL injection may be possible.
URL	https://localhost:8443/admin/users/edit/1
Node Name	<code>https://localhost:8443/admin/users/edit/1 ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,secondaryPhone)</code>
Method	POST
Attack	'
Evidence	HTTP/1.1 500
Other Info	
Instances	1
	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use <code>PreparedStatement</code> or <code>CallableStatement</code>, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do <i>*not*</i> concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!

Solution	Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact. Grant the minimum database access that is necessary for the application.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
CWE Id	89
WASC Id	19
Plugin Id	40018

High	SQL Injection - SQLite (Time Based)
Description	SQL injection may be possible.
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,mainPhone,name,newPassword,oldPassword,secondaryPhone)
Method	POST
Attack	case randomblob(10000000) when not null then 1 else 1 end
Evidence	
Other Info	The query time is controllable using parameter value [case randomblob(10000000) when not null then 1 else 1 end], which caused the request to take [311] milliseconds, parameter value [case randomblob(100000000) when not null then 1 else 1 end], which caused the request to take [627] milliseconds, when the original unmodified query with value [ZAP] took [177] milliseconds.
Instances	1
Solution	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality! Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.

	Grant the minimum database access that is necessary for the application.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
CWE Id	89
WASC Id	19
Plugin Id	40024

Medium	Buffer Overflow
Description	Buffer overflow errors are characterized by the overwriting of memory spaces of the background
URL	https://localhost:8443/admin-login?error
Node Name	https://localhost:8443/admin-login (error)
Method	GET
Attack	HBoakiUOxphCKFvpSljIUhAXNdEPFXSsuERuCxtLPoRlqmkgCXgqeaMCyguWnkbYayFpiYdiv
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/reviews?tourId=3
Node Name	https://localhost:8443/admin/reviews (tourId)
Method	GET
Attack	NGkMEBobpNfKtSwafRYPWSBVbkAQRWHgVuWfVwdcfojMNbjkawnlmejZeVlqGfHKyTyTeXF
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/guides/add
Node Name	https://localhost:8443/admin/guides/add ()(_csrf,imageFile,lastName,name,price,tourId)
Method	POST
Attack	SaGTdUeTkikiBHGRxIbcaXititRDXovDwaTHUdgrMchJbFISZfxMVYbnThquwcPcARfvQiXClyhY
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/guides/add
Node Name	https://localhost:8443/admin/guides/add ()(_csrf,imageFile,lastName,name,price,tourId)
Method	POST
Attack	HsqlIDJbwCTAmiKErDeHvnCRZGZWaaKCUqddKxRUBawfNsjXPhniulliFVqSKbAkGltOPEfvmlI
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/review-hide/1?hide=true
Node Name	https://localhost:8443/admin/review-hide/1 (hide)(_csrf)
Method	POST

Attack	ljCfnFnvpUxVEUXxxaZplytSaiqGCUZjQJZFaNCUyrNsEwpufuZrVYqprUclKWoaAjaLDfqinRfcVa
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/review-hide/2?hide=true
Node Name	https://localhost:8443/admin/review-hide/2 (hide)(_csrf)
Method	POST
Attack	buvQnEGfNtIEKZQRRsBjQPMLGxPCaSACRnfOFNRhMnAPADFGJeKNdixDTEdiGKwkGZtRF
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/users/edit/1
Node Name	https://localhost:8443/admin/users/edit/1 ()(_csrf,email,enabled,imageFile,lastName,mainPhone
Method	POST
Attack	WHdlHuZsMGRRpfImhWboCyrSnXDtioFukUFuWicUgBscFEEoiVqfDGpTCWhmIFTJUwqdadW
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/users/edit/2
Node Name	https://localhost:8443/admin/users/edit/2 ()(_csrf,email,enabled,imageFile,lastName,mainPhone
Method	POST
Attack	IEaPDxmylOOQwWsSXJXVuNvPPnEQvIPYjmZFjtohKgOloMdrQlgbRKGQODJpLXnBDqtwxbZ
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/users/edit/2
Node Name	https://localhost:8443/admin/users/edit/2 ()(_csrf,email,enabled,imageFile,lastName,mainPhone
Method	POST
Attack	KDNHlctdnvZWGVrniZoDERqAlmyJJbkaExnESCqpjbpkXLWTeJGFxUTOaWEflxYXYTiTyAZyl
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/users/edit/3
Node Name	https://localhost:8443/admin/users/edit/3 ()(_csrf,email,enabled,imageFile,lastName,mainPhone
Method	POST
Attack	ubOAnmPdeXJrLPIWQGpWohqUPCsKYJFthXeZpLqcUBXdjlxmHkfmMcUMYAjbTMAdBdACpw
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/users/edit/3

Node Name	https://localhost:8443/admin/users/edit/3 ()(_csrf,email,enabled,imageFile,lastName,mainPhone
Method	POST
Attack	eRbuGJZqqsuExhaOrsAbXkrBQSLNgvDLJPMPNyPPNCtsQmyWotinKXfIGOsCsplZIJjeubZZQ
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/admin/users/edit/5
Node Name	https://localhost:8443/admin/users/edit/5 ()(_csrf,email,enabled,imageFile,lastName,mainPhone
Method	POST
Attack	BeoQkxKETrciHBWoMUIttmbQqlwfhpchCQpjaoPqmCaLfwkdrSorwersvvPKrhXhcbPAguZCdJA
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,m
Method	POST
Attack	qeLfqlUPWEDtNSvEfvQrVDQChvQKKmcZMOLPBKNqwgEOpSUQdtjBbWEiYodUEShdYklJrSM
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,m
Method	POST
Attack	DZhCIZXZfbcseLjmcWHrqhMRcxpLKPAOLgigOXRYuLwSvCOEDwPSttIKEDCHBlpfnoKkbhp
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,m
Method	POST
Attack	GATAZXIZTENEHAaBQwLMXUhXIGnfahAoHYtqaFZUOsxraohAVEldboZxYDXTidNirwWavtoc
Evidence	Connection: close
Other Info	Potential Buffer Overflow. The script closed the connection and threw a 500 Internal Server Error
Instances	15
Solution	Rewrite the background program using proper return length checking. This will require a recom
Reference	https://owasp.org/www-community/attacks/Buffer_overflow_attack
CWE Id	120
WASC Id	7
Plugin Id	30001

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://localhost:8443/packages
Node Name	https://localhost:8443/packages
Method	GET
Attack	
Evidence	
Other Info	
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register
Method	GET
Attack	
Evidence	
Other Info	
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Format String Error
Description	A Format String error occurs when the submitted data of an input string is evaluated as a command by the application.

URL	https://localhost:8443/admin/guides/add
Node Name	https://localhost:8443/admin/guides/add ()(_csrf,imageFile,lastName,name,price,tourId)
Method	POST
Attack	ZAP %!s%2!s%3!s%4!s%5!s%6!s%7!s%8!s%9!s%10!s%11!s%12!s%13!s%14!s%15!s%16!s%17!s%18!s%19!s%20!s%21!n%22!n%23!n%24!n%25!n%26!n%27!n%28!n%29!n%30!n%31!n%32!n%33!n%34!n%35!n%36!n%37!n%38!n%39!n%40!n
Evidence	
Other Info	Potential Format String Error. The script closed the connection on a Microsoft format string error.
URL	https://localhost:8443/admin/users/edit/1
Node Name	https://localhost:8443/admin/users/edit/1 ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,secondaryPhone)
Method	POST
Attack	ZAP%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s
Evidence	
Other Info	Potential Format String Error. The script closed the connection on a /%s.
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,mainPhone,name,newPassword,oldPassword,secondaryPhone)
Method	POST
Attack	ZAP%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s
Evidence	
Other Info	Potential Format String Error. The script closed the connection on a /%s.
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,mainPhone,name,newPassword,oldPassword,secondaryPhone)
Method	POST
Attack	ZAP %!s%2!s%3!s%4!s%5!s%6!s%7!s%8!s%9!s%10!s%11!s%12!s%13!s%14!s%15!s%16!s%17!s%18!s%19!s%20!s%21!n%22!n%23!n%24!n%25!n%26!n%27!n%28!n%29!n%30!n%31!n%32!n%33!n%34!n%35!n%36!n%37!n%38!n%39!n%40!n
Evidence	
Other Info	Potential Format String Error. The script closed the connection on a Microsoft format string error.
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,mainPhone,name,newPassword,oldPassword,secondaryPhone)
Method	POST
Attack	ZAP%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s%n%s
Evidence	
Other Info	Potential Format String Error. The script closed the connection on a /%s.
URL	https://localhost:8443/profile/update

Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,mainPhone,name,newPassword,oldPassword,secondaryPhone)
Method	POST
Attack	ZAP %!s%2!s%3!s%4!s%5!s%6!s%7!s%8!s%9!s%10!s%11!s%12!s%13!s%14!s%15!s%16!s%17!s%18!s%19!s%20!s%21!n%22!n%23!n%24!n%25!n%26!n%27!n%28!n%29!n%30!n%31!n%32!n%33!n%34!n%35!n%36!n%37!n%38!n%39!n%40!n
Evidence	
Other Info	Potential Format String Error. The script closed the connection on a Microsoft format string error.
Instances	6
Solution	Rewrite the background program using proper deletion of bad character strings. This will require a recompile of the background executable.
Reference	https://owasp.org/www-community/attacks/Format_string_attack
CWE Id	134
WASC Id	6
Plugin Id	30002

Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=Jost:wght@500;600&family=Roboto&display=swap" rel="stylesheet">
Other Info	
Instances	Systemic
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Medium	Vulnerable JS Library
Description	The identified library appears to be vulnerable.
URL	https://localhost:8443/vendor/datatables/jquery.dataTables.min.js
Node Name	https://localhost:8443/vendor/datatables/jquery.dataTables.min.js
Method	GET
Attack	
Evidence	l.version="1.10.24";l.settings=[];l.models={};l.models.oSearch
Other Info	The identified library jquery.datatables, version 1.10.24 is vulnerable. CVE-2021-23445 https://cdn.datatables.net/1.11.3/ https://github.com/advisories/GHSA-h73q-5wmj-q8pj https://github.com/DataTables/Dist-DataTables/commit/59a8d3f8a3c1138ab08704e783bc52bfe88d7c9b

Instances	1
Solution	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	
Plugin Id	10003

Low	Application Error Disclosure
Description	This page contains an error/warning message that may disclose sensitive information like the log produced the unhandled exception. This information can be used to launch further attacks against the application. The alert could be a false positive if the error message is found inside a document.
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin-login
Node Name	https://localhost:8443/admin-login
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin-login?error
Node Name	https://localhost:8443/admin-login (error)
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/guides/edit/register
Node Name	https://localhost:8443/admin/guides/edit/register
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/guides/register
Node Name	https://localhost:8443/admin/guides/register

Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/js/sb-admin-2.min.js
Node Name	https://localhost:8443/admin/js/sb-admin-2.min.js
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/register
Node Name	https://localhost:8443/admin/register
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/tour-edit/register
Node Name	https://localhost:8443/admin/tour-edit/register
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/users/edit/register
Node Name	https://localhost:8443/admin/users/edit/register
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/users/register
Node Name	https://localhost:8443/admin/users/register
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	

URL	https://localhost:8443/admin/vendor/bootstrap/js/bootstrap.bundle.min.js
Node Name	https://localhost:8443/admin/vendor/bootstrap/js/bootstrap.bundle.min.js
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/vendor/jquery-easing/jquery.easing.min.js
Node Name	https://localhost:8443/admin/vendor/jquery-easing/jquery.easing.min.js
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/vendor/jquery/jquery.min.js
Node Name	https://localhost:8443/admin/vendor/jquery/jquery.min.js
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/cart?token=-5f12NU8-WU_e873jJgSTHmmdlWz6r7pUc2Wq2JhhanDtVYwqSR4ewMnAMSHq2TvLUmLkjFpLCVXp_
Node Name	https://localhost:8443/cart (token)
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/cart/add
Node Name	https://localhost:8443/cart/add
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/checkout
Node Name	https://localhost:8443/checkout
Method	GET
Attack	

Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/css
Node Name	https://localhost:8443/css
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/favicon.ico
Node Name	https://localhost:8443/favicon.ico
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/guides
Node Name	https://localhost:8443/guides
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/images
Node Name	https://localhost:8443/images
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/images/default-guide.jpg
Node Name	https://localhost:8443/images/default-guide.jpg
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/index
Node Name	https://localhost:8443/index

Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/logout
Node Name	https://localhost:8443/logout
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/packages
Node Name	https://localhost:8443/packages
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/profile
Node Name	https://localhost:8443/profile
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	

URL	https://localhost:8443/profile?showLogout=true
Node Name	https://localhost:8443/profile (showLogout)
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/review-user
Node Name	https://localhost:8443/review-user
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/robots.txt
Node Name	https://localhost:8443/robots.txt
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	

Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/sitemap.xml
Node Name	https://localhost:8443/sitemap.xml
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details
Node Name	https://localhost:8443/tour-details
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details/1
Node Name	https://localhost:8443/tour-details/1
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details/2
Node Name	https://localhost:8443/tour-details/2
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details/3
Node Name	https://localhost:8443/tour-details/3
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details/index.html
Node Name	https://localhost:8443/tour-details/index.html

Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/tour-details/packages.html
Node Name	https://localhost:8443/tour-details/packages.html
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user
Node Name	https://localhost:8443/user
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user/1
Node Name	https://localhost:8443/user/1
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user/1/image
Node Name	https://localhost:8443/user/1/image
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user/2/image
Node Name	https://localhost:8443/user/2/image
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	

URL	https://localhost:8443/user/3/image
Node Name	https://localhost:8443/user/3/image
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user/4/image
Node Name	https://localhost:8443/user/4/image
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user/5/image
Node Name	https://localhost:8443/user/5/image
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user/6/image
Node Name	https://localhost:8443/user/6/image
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/user/admin-login
Node Name	https://localhost:8443/user/admin-login
Method	GET
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/review-hide/3?hide=true
Node Name	https://localhost:8443/admin/review-hide/3 (hide)(<u>_csrf</u>)
Method	POST
Attack	

Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/tour-delete/1
Node Name	https://localhost:8443/admin/tour-delete/1 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/tour-delete/2
Node Name	https://localhost:8443/admin/tour-delete/2 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/tour-edit/3
Node Name	https://localhost:8443/admin/tour-edit/3 ()(_csrf,description,duration,hotelIncluded,imageFile,nar
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/users/delete/1
Node Name	https://localhost:8443/admin/users/delete/1 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/admin/users/edit/4
Node Name	https://localhost:8443/admin/users/edit/4 ()(_csrf,email,enabled,imageFile,lastName,mainPhone secondaryPhone)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/delete/1
Node Name	https://localhost:8443/notifications/delete/1 ()(_csrf)

Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/delete/2
Node Name	https://localhost:8443/notifications/delete/2 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/delete/3
Node Name	https://localhost:8443/notifications/delete/3 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/delete/4
Node Name	https://localhost:8443/notifications/delete/4 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/delete/5
Node Name	https://localhost:8443/notifications/delete/5 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/delete/6
Node Name	https://localhost:8443/notifications/delete/6 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	

URL	https://localhost:8443/notifications/read/1
Node Name	https://localhost:8443/notifications/read/1 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/read/2
Node Name	https://localhost:8443/notifications/read/2 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/read/3
Node Name	https://localhost:8443/notifications/read/3 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/read/4
Node Name	https://localhost:8443/notifications/read/4 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/read/5
Node Name	https://localhost:8443/notifications/read/5 ()(_csrf)
Method	POST
Attack	
Evidence	HTTP/1.1 500
Other Info	
URL	https://localhost:8443/notifications/read/6
Node Name	https://localhost:8443/notifications/read/6 ()(_csrf)
Method	POST
Attack	

Evidence	HTTP/1.1 500
Other Info	
Instances	67
Solution	Review the source code of this page. Implement custom error pages. Consider implementing a unique error reference/identifier to the client (browser) while logging the details on the server to them to the user.
Reference	
CWE Id	550
WASC Id	13
Plugin Id	90022

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	https://localhost:8443/admin-login
Node Name	https://localhost:8443/admin-login
Method	GET
Attack	
Evidence	Set-Cookie: JSESSIONID
Other Info	
URL	https://localhost:8443/cart/add/2
Node Name	https://localhost:8443/cart/add/2
Method	GET
Attack	
Evidence	Set-Cookie: JSESSIONID
Other Info	
Instances	Systemic
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Cross-Domain JavaScript Source File Inclusion
Description	The page includes one or more script files from a third-party domain.
URL	https://localhost:8443/packages
Node Name	https://localhost:8443/packages
Method	GET
Attack	
Evidence	<script src="https://ajax.googleapis.com/ajax/libs/jquery/3.6.4/jquery.min.js"></script>

Other Info	
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	<script src="https://ajax.googleapis.com/ajax/libs/jquery/3.6.4/jquery.min.js"></script>
Other Info	
Instances	Systemic
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
CWE Id	829
WASC Id	15
Plugin Id	10017

Low	Information Disclosure - Debug Error Messages
Description	The response appeared to contain common error messages returned by platforms such as ASP servers such as IIS and Apache. You can configure the list of common debug messages.
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin-login
Node Name	https://localhost:8443/admin-login
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin-login?error
Node Name	https://localhost:8443/admin-login (error)
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/guides/edit/register

Node Name	https://localhost:8443/admin/guides/edit/register
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/guides/register
Node Name	https://localhost:8443/admin/guides/register
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/register
Node Name	https://localhost:8443/admin/register
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/tour-edit/register
Node Name	https://localhost:8443/admin/tour-edit/register
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/users/edit/register
Node Name	https://localhost:8443/admin/users/edit/register
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/users/register
Node Name	https://localhost:8443/admin/users/register
Method	GET
Attack	
Evidence	Internal Server Error

Other Info	
URL	https://localhost:8443/cart?token=-5f12NU8-WU_e873jJgSTHmmdlWz6r7pUc2Wq2JhhanDtVYwqSR4ewMnAMSHq2TvLUmLkjEpLCVXp_
Node Name	https://localhost:8443/cart (token)
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/cart/add
Node Name	https://localhost:8443/cart/add
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/checkout
Node Name	https://localhost:8443/checkout
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/css
Node Name	https://localhost:8443/css
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/favicon.ico
Node Name	https://localhost:8443/favicon.ico
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/guides
Node Name	https://localhost:8443/guides

Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/images
Node Name	https://localhost:8443/images
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/images/default-guide.jpg
Node Name	https://localhost:8443/images/default-guide.jpg
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/index
Node Name	https://localhost:8443/index
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	

URL	https://localhost:8443/logout
Node Name	https://localhost:8443/logout
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/packages
Node Name	https://localhost:8443/packages
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/profile
Node Name	https://localhost:8443/profile
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/profile?showLogout=true
Node Name	https://localhost:8443/profile (showLogout)
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register
Method	GET
Attack	

Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/review-user
Node Name	https://localhost:8443/review-user
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/robots.txt
Node Name	https://localhost:8443/robots.txt
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/sitemap.xml
Node Name	https://localhost:8443/sitemap.xml
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details
Node Name	https://localhost:8443/tour-details
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details/1
Node Name	https://localhost:8443/tour-details/1

Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details/2
Node Name	https://localhost:8443/tour-details/2
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details/3
Node Name	https://localhost:8443/tour-details/3
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details/index.html
Node Name	https://localhost:8443/tour-details/index.html
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/tour-details/packages.html
Node Name	https://localhost:8443/tour-details/packages.html
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user
Node Name	https://localhost:8443/user
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	

URL	https://localhost:8443/user/1
Node Name	https://localhost:8443/user/1
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user/1/image
Node Name	https://localhost:8443/user/1/image
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user/2/image
Node Name	https://localhost:8443/user/2/image
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user/3/image
Node Name	https://localhost:8443/user/3/image
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user/4/image
Node Name	https://localhost:8443/user/4/image
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user/5/image
Node Name	https://localhost:8443/user/5/image
Method	GET
Attack	

Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user/6/image
Node Name	https://localhost:8443/user/6/image
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/user/admin-login
Node Name	https://localhost:8443/user/admin-login
Method	GET
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/review-hide/3?hide=true
Node Name	https://localhost:8443/admin/review-hide/3 (hide)(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/tour-delete/1
Node Name	https://localhost:8443/admin/tour-delete/1 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/tour-delete/2
Node Name	https://localhost:8443/admin/tour-delete/2 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/tour-edit/3
Node Name	https://localhost:8443/admin/tour-edit/3 ()(_csrf,description,duration,hotelIncluded,imageFile,nar

Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/users/delete/1
Node Name	https://localhost:8443/admin/users/delete/1 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/admin/users/edit/4
Node Name	https://localhost:8443/admin/users/edit/4 ()(_csrf,email,enabled,imageFile,lastName,mainPhone,secondaryPhone)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/delete/1
Node Name	https://localhost:8443/notifications/delete/1 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/delete/2
Node Name	https://localhost:8443/notifications/delete/2 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/delete/3
Node Name	https://localhost:8443/notifications/delete/3 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	

URL	https://localhost:8443/notifications/delete/4
Node Name	https://localhost:8443/notifications/delete/4 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/delete/5
Node Name	https://localhost:8443/notifications/delete/5 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/delete/6
Node Name	https://localhost:8443/notifications/delete/6 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/read/1
Node Name	https://localhost:8443/notifications/read/1 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/read/2
Node Name	https://localhost:8443/notifications/read/2 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/read/3
Node Name	https://localhost:8443/notifications/read/3 ()(_csrf)
Method	POST
Attack	

Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/read/4
Node Name	https://localhost:8443/notifications/read/4 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/read/5
Node Name	https://localhost:8443/notifications/read/5 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
URL	https://localhost:8443/notifications/read/6
Node Name	https://localhost:8443/notifications/read/6 ()(_csrf)
Method	POST
Attack	
Evidence	Internal Server Error
Other Info	
Instances	63
Solution	Disable debugging messages before pushing to production.
Reference	
CWE Id	1295
WASC Id	13
Plugin Id	10023

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	https://localhost:8443/admin/users/add
Node Name	https://localhost:8443/admin/users/add ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,password,secondaryPhone)
Method	POST
Attack	
Evidence	password
Other Info	userParam=email userValue=zaproxy@example.com passwordParam=password referer=https://localhost:8443/admin/users/add csrfToken=_csrf

URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,remember-me,username)
Method	POST
Attack	
Evidence	password
Other Info	userParam=username userValue=foo-bar@example.com passwordParam=password referer=https://localhost:8443/login csrfToken=_csrf
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	password
Other Info	userParam=username userValue=foo-bar@example.com passwordParam=password referer=https://localhost:8443/admin-login?error csrfToken=_csrf
Instances	3
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	GET for POST
Description	A request that was originally observed as a POST was also accepted as a GET. This issue does not exist in itself, however, it may facilitate simplification of other attacks. For example if the original POST is not required then this finding may indicate that a simplified (GET based) XSS may also be possible.
URL	https://localhost:8443/admin/review-hide/3?hide=true
Node Name	https://localhost:8443/admin/review-hide/3 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/admin/review-hide/3?_csrf=4s3imfrmdWwVjMnOIH4FQDbjFUR4Dv:1dMuaqRa_r0v7a_JvRR1Q47_msEFMxcwPVOHwdNp_DZoXv9t5uVNCdd5-N HTTP/1.1
Other Info	
URL	https://localhost:8443/admin/tour-delete/1
Node Name	https://localhost:8443/admin/tour-delete/1 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/admin/tour-delete/1?_csrf=_qrYUqhvhvQk3qptKq-Cs7R2xzjNeHULIHHiSc2CtXPMw7M6DzpngN3uWjzEayasom82Y3iiH4ws7JSHI8kimQIOeOsUH
Other Info	
URL	https://localhost:8443/admin/tour-delete/2
Node	

Name	https://localhost:8443/admin/tour-delete/2 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/admin/tour-delete/2?_csrf=_qrYUhqhvQk3qptKq-Cs7R2xzjNeHULlHiSc2CtXPMw7M6DzpNgN3uWjzEayasom82Y3iiH4ws7JSHI8kimQIOeOsUH
Other Info	
URL	https://localhost:8443/admin/tour-edit/3
Node Name	https://localhost:8443/admin/tour-edit/3 (_csrf,description,duration,hotelIncluded,imageFile,name)
Method	GET
Attack	
Evidence	GET https://localhost:8443/admin/tour-edit/3?_csrf=F3nsR8WqN1MYdaE61JopG97th1IPx0gh78nS1LogUZhJTqrAJ0rUIqSdBWs1FpFY5LcdhfJqm&description=Zaproxy%20alias%20impedit%20expedita%20quisquam%20pariatur%20eveniet%20dolores%20rem%20quia%20dignissimos.&duration=0&hotelIncluded=true&imageFile.txt&name=ZAP&numPeople=1&price=0.0 HTTP/1.1
Other Info	
URL	https://localhost:8443/admin/users/delete/1
Node Name	https://localhost:8443/admin/users/delete/1 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/admin/users/delete/1?_csrf=IOPJ2AZowp8WkNt3hvW5LRsC4mLgSsVttiNH40z1qFcM7UoNHdYBHbadx-DAA5 HTTP/1.1
Other Info	
URL	https://localhost:8443/notifications/delete/1
Node Name	https://localhost:8443/notifications/delete/1 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/delete/1?_csrf=Qalau6n3tm-6tWtcdTQtCwavMWBnJeoRRkZODOZHFgCHYka0xY7UqilFbwrrfDA HTTP/1.1
Other Info	
URL	https://localhost:8443/notifications/delete/2
Node Name	https://localhost:8443/notifications/delete/2 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/delete/2?_csrf=PEer478LTkZc3rxFfSBOWiDn2TTOdDjx5hBRuoR6gG0lwTpVDHSTht48fH5xvYwnTQ1681
Other Info	
URL	https://localhost:8443/notifications/delete/3

Node Name	https://localhost:8443/notifications/delete/3 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/delete/3?_csrf=PEer478LTkZc3rxFFSBOWiDn2TTOdDjx5hBRuoR6gG0lwTpVDHSTht48fH5xvYwnTQ1681
Other Info	
URL	https://localhost:8443/notifications/delete/4
Node Name	https://localhost:8443/notifications/delete/4 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/delete/4?_csrf=2A5GOM-clrQRZp5NiCdViIOD3WwncVXw6rplw8Ba4vuAphu7a18FRCST8ze70n1Y01jdPEYgmX HTTP/1.1
Other Info	
URL	https://localhost:8443/notifications/delete/5
Node Name	https://localhost:8443/notifications/delete/5 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/delete/5?_csrf=wdQ4UWB2bRK1S7tm4Y1zrOd0aD_ZCpZOP6IOGJxHwyawu_HB8ecANAFBXyqYKIsEC HTTP/1.1
Other Info	
URL	https://localhost:8443/notifications/delete/6
Node Name	https://localhost:8443/notifications/delete/6 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/delete/6?_csrf=Avz265KITpBUf63LljQcmTMopojXLUP27rGGecw038VwOxiaMs_OjvO_fKh5HJ2pphkoqg1
Other Info	
URL	https://localhost:8443/notifications/read/1
Node Name	https://localhost:8443/notifications/read/1 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/read/1?_csrf=Qalau6n3tm-6tWtcdTQtCwavMWBnJeo3tRRkZODOZHFgCHYka0xY7UqilFbwrrfDA HTTP/1.1
Other Info	
URL	https://localhost:8443/notifications/read/2

Node Name	https://localhost:8443/notifications/read/2 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/read/2?_csrf=PEer478LTkZc3rxFFSBOWiDn2TTOdDjx5hBRuoR6gG0lwTpVDHSTht48fH5xvYwnTQ1681
Other Info	
URL	https://localhost:8443/notifications/read/3
Node Name	https://localhost:8443/notifications/read/3 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/read/3?_csrf=PEer478LTkZc3rxFFSBOWiDn2TTOdDjx5hBRuoR6gG0lwTpVDHSTht48fH5xvYwnTQ1681
Other Info	
URL	https://localhost:8443/notifications/read/4
Node Name	https://localhost:8443/notifications/read/4 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/read/4?_csrf=Qalau6n3tm-6tWtcdTQtCwavMWBnJeo3tRRkZODOZHFgCHYka0xY7UqilFbwrrfDA HTTP/1.1
Other Info	
URL	https://localhost:8443/notifications/read/5
Node Name	https://localhost:8443/notifications/read/5 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/read/5?_csrf=PzIN_IAFMRag1ZN2-opn8qQDq-Q3msis2_SLrpPqOHDwp1meEyAy6NtqMUyqdTwZE1htxSoquBFieWrt6MLozeDJPh HTTP/1.1
Other Info	
URL	https://localhost:8443/notifications/read/6
Node Name	https://localhost:8443/notifications/read/6 (_csrf)
Method	GET
Attack	
Evidence	GET https://localhost:8443/notifications/read/6?_csrf=-5NsCx7a3d1aS9DTy8gjjjJrdr8Xoh7rDK8UXvQddW4dymn3Gap8_UDInWBCzW6Jb HTTP/1.1
Other Info	
Instances	17
Solution	Ensure that only POST is accepted where POST is expected.

Reference	
CWE Id	16
WASC Id	20
Plugin Id	10058

Informational	Information Disclosure - Sensitive Information in URL
---------------	---

Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and compliance policies. You can configure the list of strings for this check to add or remove values
URL	https://localhost:8443/admin/guides?token=r1DH1bk0d6BSYJQLc6T6_i2Brhwyuj4QFf_SgAZT6a9ofrMUn2P_sNgDRZh_A6RpQ4nC
Node Name	https://localhost:8443/admin/guides (token)
Method	GET
Attack	
Evidence	token
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern
URL	https://localhost:8443/admin/tours?token=Kab-fPHbUklIJEedF7pv6xfO9MmwjE0PI-zGIKVLIIW4OwqnGZXGGZDsYHoIR3f_J5db2CL42fHVtC4iRdzyppZZ48GOPCTrB
Node Name	https://localhost:8443/admin/tours (token)
Method	GET
Attack	
Evidence	token
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern
URL	https://localhost:8443/cart?token=-5f12NU8-WU_e873jJgSTHmmlLwZ6r7pUc2Wq2JhhanDtVYwqSR4ewMnAMSHq2TvLUmLkjFpLCVXp_
Node Name	https://localhost:8443/cart (token)
Method	GET
Attack	
Evidence	token
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern
Instances	Systemic
Solution	Do not pass sensitive information in URIs.
Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	Information Disclosure - Suspicious Comments
---------------	--

Description	The response appears to contain suspicious comments which may help an attacker.
URL	https://localhost:8443/js/sb-admin-2.min.js
Node Name	https://localhost:8443/js/sb-admin-2.min.js

Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "//startbootstrap evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/profile
Node Name	https://localhost:8443/profile
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "// if user adds i are required", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/vendor/jquery/jquery.min.js
Node Name	https://localhost:8443/vendor/jquery/jquery.min.js
Method	GET
Attack	
Evidence	username
Other Info	The following pattern was used: \bUSERNAME\b and was detected in likely comment: "//,Ot={}, createElement("a");function lt(o){return function(e,t){\"string\"!=typeof e&&(t=e,e=\"*\");v\", see evidence comment/snippet.
URL	https://localhost:8443/admin
Node Name	https://localhost:8443/admin
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin
Node Name	https://localhost:8443/admin
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin-login
Node Name	https://localhost:8443/admin-login
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 2 times, the first in likely comment see evidence field for the suspicious comment/snippet.

URL	https://localhost:8443/admin-login
Node Name	https://localhost:8443/admin-login
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 2 times, the first in likely comment ">", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin-login?error
Node Name	https://localhost:8443/admin-login (error)
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 2 times, the first in likely comment ">", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin-login?error
Node Name	https://localhost:8443/admin-login (error)
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 2 times, the first in likely comment ">", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/404
Node Name	https://localhost:8443/admin/404
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/404
Node Name	https://localhost:8443/admin/404
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment ">", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/blank
Node Name	https://localhost:8443/admin/blank
Method	GET
Attack	

Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/blank
Node Name	https://localhost:8443/admin/blank
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/buttons
Node Name	https://localhost:8443/admin/buttons
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/buttons
Node Name	https://localhost:8443/admin/buttons
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/cards
Node Name	https://localhost:8443/admin/cards
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/cards
Node Name	https://localhost:8443/admin/cards
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/charts
Node Name	https://localhost:8443/admin/charts

Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/charts
Node Name	https://localhost:8443/admin/charts
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides
Node Name	https://localhost:8443/admin/guides
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides
Node Name	https://localhost:8443/admin/guides
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides?token=r1DH1bk0d6BSYJQLc6T6_i2Brhwyuj4QFf_SgAZT6a9ofrMUn2P_sNgDRZh_A6RpQ4nC
Node Name	https://localhost:8443/admin/guides (token)
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides?token=r1DH1bk0d6BSYJQLc6T6_i2Brhwyuj4QFf_SgAZT6a9ofrMUn2P_sNgDRZh_A6RpQ4nC
Node Name	https://localhost:8443/admin/guides (token)
Method	GET
Attack	
Evidence	user
Other	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment

Info	see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/add
Node Name	https://localhost:8443/admin/guides/add
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display c field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/add
Node Name	https://localhost:8443/admin/guides/add
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/1
Node Name	https://localhost:8443/admin/guides/edit/1
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display c field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/1
Node Name	https://localhost:8443/admin/guides/edit/1
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/2
Node Name	https://localhost:8443/admin/guides/edit/2
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display c field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/2
Node Name	https://localhost:8443/admin/guides/edit/2
Method	GET

Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/3
Node Name	https://localhost:8443/admin/guides/edit/3
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display c field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/3
Node Name	https://localhost:8443/admin/guides/edit/3
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/4
Node Name	https://localhost:8443/admin/guides/edit/4
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display c field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/4
Node Name	https://localhost:8443/admin/guides/edit/4
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/5
Node Name	https://localhost:8443/admin/guides/edit/5
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display c field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/guides/edit/5

Node Name	https://localhost:8443/admin/guides/edit/5
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/index
Node Name	https://localhost:8443/admin/index
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/index
Node Name	https://localhost:8443/admin/index
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/reviews
Node Name	https://localhost:8443/admin/reviews
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 3 times, the first in likely comment ">", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/reviews
Node Name	https://localhost:8443/admin/reviews
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/reviews?token=k4qtQtmKh5MQua8giZwrC2PIi5AmSlSqb3iVnC8IM07omDpCo7mVJ7i9tas92p9CubEfOf
Node Name	https://localhost:8443/admin/reviews (token)
Method	GET
Attack	
Evidence	admin

Other Info	The following pattern was used: \bADMIN\b and was detected 3 times, the first in likely comment ">", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/reviews?token=k4qtQtmKh5MQua8giZwrC2PIi5AmSlSqB3iVnC8IM07omDpCo7mVJ7i9tas92p9CubEfOf
Node Name	https://localhost:8443/admin/reviews (token)
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/reviews?tourId=2
Node Name	https://localhost:8443/admin/reviews (tourId)
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 3 times, the first in likely comment ">", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/reviews?tourId=2
Node Name	https://localhost:8443/admin/reviews (tourId)
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tour-add
Node Name	https://localhost:8443/admin/tour-add
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tour-add
Node Name	https://localhost:8443/admin/tour-add
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tour-edit/1
Node Name	https://localhost:8443/admin/tour-edit/1

Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tour-edit/1
Node Name	https://localhost:8443/admin/tour-edit/1
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tour-edit/2
Node Name	https://localhost:8443/admin/tour-edit/2
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tour-edit/2
Node Name	https://localhost:8443/admin/tour-edit/2
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tour-edit/3
Node Name	https://localhost:8443/admin/tour-edit/3
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tour-edit/3
Node Name	https://localhost:8443/admin/tour-edit/3
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.

URL	https://localhost:8443/admin/tours
Node Name	https://localhost:8443/admin/tours
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tours
Node Name	https://localhost:8443/admin/tours
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tours?token=Kab-fPHbUklIJEedF7pv6xfO9MmwjE0PI-zGIKVLIIW4OwqnGZXGGZDsYHoIR3f_J5db2CL42fHVtC4iRdzypZZ48GOPCTrB
Node Name	https://localhost:8443/admin/tours (token)
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/tours?token=Kab-fPHbUklIJEedF7pv6xfO9MmwjE0PI-zGIKVLIIW4OwqnGZXGGZDsYHoIR3f_J5db2CL42fHVtC4iRdzypZZ48GOPCTrB
Node Name	https://localhost:8443/admin/tours (token)
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users
Node Name	https://localhost:8443/admin/users
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users
Node Name	https://localhost:8443/admin/users
Method	GET

Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 46 times, the first in likely comment: see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users?token=nVj3cM4jibTM-hl7QiqyoYOzT6CAQK2erw3Tn089SLLR439trWvPFa8Uu4zhmSJZcgeGkraFYpjleM6zyT3nrnw/
Node Name	https://localhost:8443/admin/users (token)
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users?token=nVj3cM4jibTM-hl7QiqyoYOzT6CAQK2erw3Tn089SLLR439trWvPFa8Uu4zhmSJZcgeGkraFYpjleM6zyT3nrnw/
Node Name	https://localhost:8443/admin/users (token)
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 14 times, the first in likely comment: see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/add
Node Name	https://localhost:8443/admin/users/add
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/add
Node Name	https://localhost:8443/admin/users/add
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment: see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/edit/1
Node Name	https://localhost:8443/admin/users/edit/1
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.

URL	https://localhost:8443/admin/users/edit/1
Node Name	https://localhost:8443/admin/users/edit/1
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/edit/2
Node Name	https://localhost:8443/admin/users/edit/2
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/edit/2
Node Name	https://localhost:8443/admin/users/edit/2
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/edit/3
Node Name	https://localhost:8443/admin/users/edit/3
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/edit/3
Node Name	https://localhost:8443/admin/users/edit/3
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/edit/4
Node Name	https://localhost:8443/admin/users/edit/4
Method	GET
Attack	

Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/edit/4
Node Name	https://localhost:8443/admin/users/edit/4
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/edit/5
Node Name	https://localhost:8443/admin/users/edit/5
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/edit/5
Node Name	https://localhost:8443/admin/users/edit/5
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/utilities-animation
Node Name	https://localhost:8443/admin/utilities-animation
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/utilities-animation
Node Name	https://localhost:8443/admin/utilities-animation
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/utilities-border
Node Name	https://localhost:8443/admin/utilities-border

Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/utilities-border
Node Name	https://localhost:8443/admin/utilities-border
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/utilities-color
Node Name	https://localhost:8443/admin/utilities-color
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/utilities-color
Node Name	https://localhost:8443/admin/utilities-color
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/utilities-other
Node Name	https://localhost:8443/admin/utilities-other
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/utilities-other
Node Name	https://localhost:8443/admin/utilities-other
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.

URL	https://localhost:8443/cart
Node Name	https://localhost:8443/cart
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tried to log in -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart
Node Name	https://localhost:8443/cart
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tried to log in -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add
Node Name	https://localhost:8443/cart/add
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tried to log in -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add
Node Name	https://localhost:8443/cart/add
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tried to log in -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add/1
Node Name	https://localhost:8443/cart/add/1
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tried to log in -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add/1
Node Name	https://localhost:8443/cart/add/1
Method	GET
Attack	

Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon trie is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add/2
Node Name	https://localhost:8443/cart/add/2
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user trie is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/cart/add/2
Node Name	https://localhost:8443/cart/add/2
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon trie is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 2 times, the first in likely comment: "-->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/profile
Node Name	https://localhost:8443/profile
Method	GET
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected 3 times, the first in likely comment: "isnt admin -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/tour-details/1
Node Name	https://localhost:8443/tour-details/1
Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- Calls to ac user is logged in. -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/tour-details/2
Node Name	https://localhost:8443/tour-details/2

Method	GET
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- Calls to ac user is logged in. -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/add
Node Name	https://localhost:8443/admin/users/add ()(_csrf,email,enabled,imageFile,lastName,mainPhone,n secondaryPhone)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- display cu field for the suspicious comment/snippet.
URL	https://localhost:8443/admin/users/add
Node Name	https://localhost:8443/admin/users/add ()(_csrf,email,enabled,imageFile,lastName,mainPhone,n secondaryPhone)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected 6 times, the first in likely comment see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/contact
Node Name	https://localhost:8443/contact ()(_csrf)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user trie displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/contact
Node Name	https://localhost:8443/contact ()(_csrf)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon trie is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,remember-me,username)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user trie displayed -->", see evidence field for the suspicious comment/snippet.

URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,remember-me,username)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon trie is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user trie displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon trie is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/logout
Node Name	https://localhost:8443/logout ()(_csrf)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user trie displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/logout
Node Name	https://localhost:8443/logout ()(_csrf)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon trie is displayed -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,moldPassword,secondaryPhone)
Method	POST
Attack	

Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tried to display -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/profile/update
Node Name	https://localhost:8443/profile/update ()(_csrf,clickaction,confirmPassword,imageFile,lastName,moldPassword,secondaryPhone)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tried to display -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register ()(_csrf,email,iAgree,imageFile,lastName,mainPhone,name,password)
Method	POST
Attack	
Evidence	admin
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!-- if user tried to display -->", see evidence field for the suspicious comment/snippet.
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register ()(_csrf,email,iAgree,imageFile,lastName,mainPhone,name,password)
Method	POST
Attack	
Evidence	user
Other Info	The following pattern was used: \bUSER\b and was detected in likely comment: "<!-- if anon tried to display -->", see evidence field for the suspicious comment/snippet.
Instances	105
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	https://localhost:8443/packages
Node Name	https://localhost:8443/packages
Method	GET
Attack	
Evidence	<i class="fab fa-twitter"></i>
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.

URL	https://localhost:8443/register
Node Name	https://localhost:8443/register
Method	GET
Attack	
Evidence	<i class="fab fa-twitter"></i>
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	<i class="fab fa-twitter"></i>
Other Info	Links have been found that do not have traditional href attributes, which is an indication that this is a modern web application.
Instances	Systemic
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	https://localhost:8443
Node Name	https://localhost:8443
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/admin-login

Node Name	https://localhost:8443/admin-login
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/booking-user
Node Name	https://localhost:8443/booking-user
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/cart/add/2
Node Name	https://localhost:8443/cart/add/2
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/profile
Node Name	https://localhost:8443/profile
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/review-user
Node Name	https://localhost:8443/review-user
Method	GET
Attack	
Evidence	JSESSIONID

Other Info	cookie:JSESSIONID
URL	https://localhost:8443/services
Node Name	https://localhost:8443/services
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/tour-details/1
Node Name	https://localhost:8443/tour-details/1
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/tour-details/2
Node Name	https://localhost:8443/tour-details/2
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,remember-me,username)
Method	POST
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/register
Node Name	https://localhost:8443/register ()(_csrf,email,iAgree,imageFile,lastName,mainPhone,name,password,secondaryPhone)
Method	POST

Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443
Node Name	https://localhost:8443
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login
Node Name	https://localhost:8443/login
Method	GET
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
URL	https://localhost:8443/login-check
Node Name	https://localhost:8443/login-check ()(_csrf,password,username)
Method	POST
Attack	
Evidence	JSESSIONID
Other Info	cookie:JSESSIONID
Instances	18
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer

Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	https://localhost:8443/
Node Name	https://localhost:8443/
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104

Informational	User Controllable HTML Element Attribute (Potential XSS)
Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	https://localhost:8443/admin/reviews?tourId=1
Node Name	https://localhost:8443/admin/reviews (tourId)
Method	GET
Attack	
Evidence	
Other	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://localhost:8443/admin/reviews?tourId=1 appears to include user input in: a(n) [meta] tag [content] attribute The

Info	user input found was: tourId=1 The user-controlled value was: width=device-width, initial-scale=1, shrink-to-fit=no
URL	https://localhost:8443/admin/users/add
Node Name	https://localhost:8443/admin/users/add ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,password,secondaryPhone)
Method	POST
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://localhost:8443/admin/users/add appears to include user input in: a(n) [a] tag [aria-expanded] attribute The user input found was: enabled=true The user-controlled value was: true
URL	https://localhost:8443/admin/users/add
Node Name	https://localhost:8443/admin/users/add ()(_csrf,email,enabled,imageFile,lastName,mainPhone,moneySpent,name,password,secondaryPhone)
Method	POST
Attack	
Evidence	
Other Info	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL: https://localhost:8443/admin/users/add appears to include user input in: a(n) [input] tag [value] attribute The user input found was: moneySpent=0.00 The user-controlled value was: 0.00
Instances	3
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031